Hands-On Projects

Project 7-1: Kiểm tra SSL phía Máy chủ (Server) và phía Máy khách (Client)

Mục tiêu: Giải thích tầm quan trọng của các khái niệm an toàn trong môi trường doanh nghiệp.

Mô tả: Trong dự án này, thực hiện các bài kiểm thử trực tuyến để đánh giá mức độ an toàn của máy chủ web và trình duyệt web cục bộ của mình.

LƯU Ý: Việc các trang web thay đổi vị trí lưu trữ tập tin không phải là điều hiếm gặp. Nếu URL không còn hoạt động, hãy mở công cụ tìm kiếm và tìm "Qualys SSL Server Test."

1. Truy cập vào **www.ssllabs.com**.
2. Nhấp vào **Test your server >>**.
3. Nhấp vào trang web đầu tiên được liệt kê trong phần **Recent Best**.
4. Ghi lại điểm đánh giá của trang web này. Trong phần **Summary**, ghi chú xếp hạng tổng thể (**Overall Rating**) cùng với các điểm số về **Certificate, Protocol Support, Key Exchange** và **Cipher Strength** là các thành phần của bộ mã hóa (**cipher suite**).
5. Nếu **Overall Rating** của trang web này không phải là **A**, thì sẽ thấy danh sách các lý do. Sau khi đọc qua, có đồng ý với các lý do đó không? Tại sao?
6. Cuộn xuống phần **Certificate #1** và xem thông tin về chứng chỉ số. Trong phần **Certification Paths**, nhấp vào **Click here to expand** (nếu cần) để xem chuỗi chứng chỉ. Bạn có thể nhận xét gì về nó?
7. Cuộn xuống phần **Configuration**. Ghi lại danh sách các giao thức được hỗ trợ và không được hỗ trợ. Nếu trang web này muốn tăng cường mức độ an toàn thì giao thức nào nên bị loại bỏ? Tại sao?

8. Trong phần **Cipher Suites**, giải thích danh sách các bộ mã hóa. Lưu ý rằng chúng được liệt kê theo thứ tự ưu tiên sử dụng của máy chủ. Để tăng cường mức độ an toàn thì bộ mã hóa nào nên được liệt kê đầu tiên? Tại sao?

9. Trong phần **Handshake Simulation**, chọn trình duyệt web và hệ điều hành mà bạn đang sử dụng hoặc tương tự với thiết bị của bạn. Xem xét khả năng tương tác của máy khách với máy chủ web này. Đặc biệt chú ý đến thứ tự ưu tiên của các bộ mã hóa. Khi hoàn tất, nhấn nút quay lại trên trình duyệt.

10. Cuộn lên đầu trang và nhấp vào **Scan Another >>**.

11. Chọn một trong các trang web trong danh sách **Recent Worst**. Xem xét các mục **Summary, Authentication, Configuration, Cipher Suites** và **Handshake Simulation**. Bạn có đồng ý với điểm số của trang web này không?

12. Nếu cần, quay lại trang **SSL Report**, sau đó nhấp vào **Scan Another >>**.

13. Nhập tên miền của trường học hoặc công ty bạn đang làm việc và tạo báo cáo. Điểm số nhận được là bao nhiêu?

14. Xem xét các mục **Summary, Authentication, Configuration, Cipher Suites** và **Handshake Simulation**. Bạn có đồng ý với điểm số này không?

15. Lập danh sách **năm lỗ hổng bảo mật hàng đầu** theo thứ tự ưu tiên mà bạn cho rằng cần khắc phục. Nếu có thể, hãy chia sẻ danh sách này với bộ phận IT để họ có thể thực hiện các biện pháp phù hợp.

16. Nhấp vào **Projects**.

17. Kiểm tra khả năng của trình duyệt web của bạn. Nhấp vào **SSL Client Test** và xem xét các thông tin hiển thị. In hoặc chụp ảnh màn hình trang này.

18. Đóng trình duyệt web.

19. Mở một trình duyệt web khác trên máy tính này hoặc trên một máy tính khác.

20. Truy cập lại **www.ssllabs.com**, nhấp vào **Projects**, sau đó chọn **SSL Client Test** để so sánh điểm số giữa hai trình duyệt. Từ góc độ an toàn, trình duyệt nào tốt hơn? Tại sao?

21. Đóng tất cả cửa sổ.

Project 7-2: Xem Chứng chỉ Số (Digital Certificates)

Mục tiêu: Triển khai hạ tầng khóa công khai (**Public Key Infrastructure - PKI**) dựa trên một kịch bản cụ thể.

Mô tả: Trong dự án này, xem thông tin chứng chỉ số bằng trình duyệt Google Chrome.

1. Mở trình duyệt Google Chrome và truy cập **www.google.com**.
2. Quan sát biểu tượng ổ khóa trên thanh địa chỉ. Mặc dù bạn không nhập https://, nhưng Google vẫn thiết lập kết nối HTTPS an toàn. Tại sao lại như vậy?
3. Nhấp vào biểu tượng ba dấu chấm dọc ở góc ngoài cùng bên phải của thanh địa chỉ.
4. Chọn **More tools**.
5. Chọn **Developer tools**.
6. Nhấp vào tab **Security** (nếu không thấy tab này, nhấp vào nút >> để hiển thị thêm tab).
7. Đọc thông tin trong phần **Security Overview**.
8. Nhấp vào **View certificate**.
9. Ghi lại các thông tin tổng quan hiển thị trong tab **General**.
10. Chuyển sang tab **Details** để xem các trường dữ liệu của chứng chỉ số **X.509**.
11. Nhấp vào **Valid to** để xem ngày hết hạn của chứng chỉ này.
12. Nhấp vào **Public key** để xem khóa công khai liên kết với chứng chỉ số này. Tại sao trang web này không lo ngại về việc phân phối khóa này? Việc nhúng khóa công khai vào chứng chỉ số giúp bảo vệ nó khỏi những kẻ giả mạo như thế nào?

13. Nhấp vào tab **Certification Path**. Vì chứng chỉ web dựa trên mô hình tin cậy phân tán (**distributed trust model**), nên sẽ có một đường dẫn đến chứng chỉ gốc (**root certificate**). Nhấp vào chứng chỉ gốc, sau đó chọn **View Certificate**.
    - Chuyển sang tab Details và nhấp vào Valid to.
    - Tại sao ngày hết hạn của chứng chỉ gốc lại dài hơn chứng chỉ của trang web?
    - Nhấp OK, sau đó nhấp OK lần nữa để đóng cửa sổ chứng chỉ.
14. Nhấp vào **Copy to File**.
15. Nhấp **Next**.
16. Quan sát các định dạng tập tin có sẵn. Bạn biết gì về từng định dạng này?
17. Nhấp **Cancel** để đóng cửa sổ.
18. Đóng tất cả cửa sổ.

Dự án 7-3: Xem Danh sách Thu hồi Chứng chỉ (Certificate Revocation Lists – CRL) và Chứng chỉ Không Đáng Tin Cậy (Untrusted Certificates)

Mục tiêu: Triển khai hạ tầng khóa công khai (**Public Key Infrastructure - PKI**) trong một kịch bản cụ thể.

Mô tả: Các chứng chỉ số bị thu hồi sẽ được liệt kê trong **Danh sách Thu hồi Chứng chỉ** (**Certificate Revocation List - CRL**), có thể được truy cập để kiểm tra trạng thái chứng chỉ của người dùng khác. Trong dự án này, bạn sẽ xem CRL và các chứng chỉ không đáng tin cậy trên máy tính Microsoft Windows của mình.

Các bước thực hiện

1. Nhấn tổ hợp phím **Windows + X**.
2. Chọn **Windows PowerShell (Admin)**.
3. Nhập lệnh certmgr.msc và nhấn **Enter**.
4. Trong khung bên trái, mở rộng **Trusted Root Certification Authorities**.
5. Trong khung bên phải, nhấp đúp vào **Certificates** để hiển thị danh sách các **Certificate Authorities (CAs)** đã được phê duyệt trên máy tính này. Cuộn xuống danh sách này. Bạn đã từng nghe về bao nhiêu CA trong số này?
6. Trong khung bên trái, mở rộng **Intermediate Certification Authorities**.
7. Nhấp đúp vào **Certificates** để xem danh sách các CA trung gian. Cuộn xuống danh sách này.
8. Trong khung bên trái, nhấp vào **Certificate Revocation List**. Khung bên phải sẽ hiển thị tất cả các chứng chỉ đã bị thu hồi.
9. Trong khung bên phải, chọn một chứng chỉ đã bị thu hồi và nhấp đúp vào nó.
10. Đọc thông tin về chứng chỉ đã bị thu hồi và nhấp vào các trường để xem thêm chi tiết nếu cần. Theo bạn, tại sao chứng chỉ này bị thu hồi? Đóng cửa sổ **Certificate Revocation List** bằng cách nhấp vào nút **OK**.

11. Trong khung bên trái, mở rộng **Untrusted Certificates**.

12. Nhấp vào **Certificate Trust List**. Khung bên phải sẽ hiển thị danh sách các chứng chỉ không còn được tin cậy.

13. Trong khung bên phải, nhấp đúp vào một chứng chỉ không đáng tin cậy. Đọc thông tin về chứng chỉ này và nhấp vào các trường để xem thêm chi tiết nếu cần. Theo bạn, tại sao chứng chỉ này không còn được tin cậy?

14. Nhấp **OK** để đóng hộp thoại **Certificate**.

15. Đóng tất cả cửa sổ.

Project 7-4: Tải và Cài đặt Chứng chỉ Số

Thời gian yêu cầu: 25 phút

Mục tiêu: Triển khai hạ tầng khóa công khai (**Public Key Infrastructure - PKI**) trong một kịch bản cụ thể.

Mô tả: Trong dự án này, tải và cài đặt một chứng chỉ số trong **Adobe Acrobat Reader DC**.

Các bước thực hiện

2. Kiểm tra xem **Adobe Acrobat Reader DC** hoặc **Adobe Acrobat Professional** đã được cài đặt trên máy tính của bạn chưa. Nếu có, bạn có thể bỏ qua các bước tải xuống và cài đặt và chuyển thẳng đến **Bước 5**.

Lưu ý: Các trang web thường thay đổi vị trí lưu trữ tập tin. Nếu liên kết không hoạt động, hãy tìm kiếm "Adobe Acrobat Reader DC Download" trên công cụ tìm kiếm.

3. Truy cập **get.adobe.com/reader/**.

4. Nhấp vào **Download Acrobat Reader**.

5. Làm theo hướng dẫn để cài đặt **Reader**.

6. Mở **Adobe Acrobat Reader DC**.

7. Nhấp vào **Edit**.

8. Nhấp vào **Preferences**.

9. Chọn **Signatures**.

10. Trong phần **Identities & Trusted Certificates**, nhấp vào **More**.

11. Trong khung bên trái, nhấp vào **Digital IDs** để hiển thị các tùy chọn, nếu cần.

12. Ở menu trên cùng của khung chính, nhấp vào biểu tượng **Add ID** (biểu tượng đầu tiên có dấu cộng).

13. Chọn **A new digital ID I want to create now** và nhấp **Next**.

14. Nếu cần, chọn **New PKCS#12 digital ID file**.

    - **PKCS#12** là gì? Nó có phần mở rộng tập tin nào?
    - Nhấp vào **Next**.

15. Nhập thông tin yêu cầu.

    - Trong phần **Key Algorithm**, nhấp vào mũi tên xuống để hiển thị hai tùy chọn.
    - Mặc định là **2048-bit RSA**, bảo mật hơn. **1024-bit RSA** ít bảo mật hơn nhưng tương thích rộng hơn.
    - Chấp nhận **2048-bit RSA**.

16. Trong phần **Use digital ID for**, nhấp vào mũi tên xuống để hiển thị ba tùy chọn.

    - Chọn mặc định **Digital Signatures and Data Encryption**.
    - Nhấp vào **Next**.

17. Tạo và nhập mật khẩu mạnh, sau đó xác nhận lại mật khẩu. Nhấp vào **Finish**.

18. Chứng chỉ số của bạn đã được tạo. Nhấp vào **Export**.

19. Nếu cần, chọn **Save the data to a file** và nhấp vào **Next**.

20. Lưu tập tin vào máy tính của bạn.

21. Đóng các cửa sổ liên quan đến việc cấu hình chứng chỉ. Bạn có thể sử dụng chứng chỉ này để gửi cho những người cần xác minh danh tính của bạn.

22. Đóng tất cả cửa sổ.